

Enterprise Risk Management – Executive Summary

Assessment Period: Q4 2025

1. Purpose and Scope

This executive summary provides a high-level view of organizational risk exposure based on likelihood and impact assessments consolidated within the Enterprise Risk Management (ERM) Dashboard. The objective is to support risk prioritization, governance oversight, and decision-making by summarizing key risk drivers, severity trends, and overall risk posture.

The analysis reflects inherent and residual risk perspectives across multiple risk categories and individual risk scenarios.

2. Overall Risk Posture

Based on the aggregated results presented in the dashboard, the organization's **overall risk status is assessed as *Moderate***.

- The **average inherent risk score** across identified risks is **12.6**, indicating a material but manageable level of exposure.
- Risk levels vary by category and scenario, highlighting the importance of targeted mitigation rather than uniform control application.

This risk posture suggests that current controls reduce exposure in several areas, while select domains continue to warrant focused attention.

3. Highest Risk Area

The dashboard identifies **Data Breach** as the **highest risk category** during the assessment period.

This designation reflects:

- Elevated likelihood and impact scores relative to other risk categories
- High inherent risk severity compared to peer risk domains

Data Breach risk remains a critical concern due to its potential impact on **confidentiality, regulatory exposure, operational disruption, and reputational harm**.

4. Risk Distribution and Severity Insights

4.1 Top Risks by Inherent Severity

Analysis of inherent risk severity (Likelihood $\times$ Impact) shows that a small subset of risks (e.g., R-002, R-003, R-005) account for a disproportionate share of total risk exposure.

This concentration indicates that:

- Risk exposure is not evenly distributed
- Prioritizing remediation for top-severity risks will yield the greatest risk reduction

4.2 Risk Severity by Category

Risk severity analysis across categories highlights notable differences:

- **Confidentiality and Access Control** risks exhibit higher inherent severity, driven by elevated impact potential.
- **Malware and Availability** risks show moderate severity, reflecting partial mitigation through existing controls.
- **Social Engineering** risks remain persistent, reinforcing the need for ongoing awareness and preventive measures.

These findings support a **risk-based allocation of resources** rather than equal treatment of all risk categories.

5. Risk Reduction and Control Effectiveness

Comparison of inherent versus residual risk indicates that controls are contributing to measurable risk reduction across several categories.

Key observations include:

- Stronger controls correlate with lower residual risk
- Residual risk remains elevated where control effectiveness is limited or uneven
- Risk reduction deltas highlight opportunities for targeted control improvements

Residual risk is used as a decision-support indicator, recognizing that risk cannot be fully eliminated.

6. Risk Status Distribution

Risk status distribution across the portfolio shows a balanced mix of:

- Open risks requiring ongoing monitoring
- Risks under mitigation
- Closed or accepted risks

This distribution reflects an active risk management posture, with risks progressing through defined lifecycle states rather than remaining static.

7. Management Implications and Recommendations

Based on the dashboard analysis, the following high-level actions are recommended:

1. **Prioritize Data Breach and Access Control risks** for enhanced mitigation and oversight
2. Focus remediation efforts on **top inherent-risk scenarios** to maximize risk reduction
3. Continue monitoring residual risk levels to ensure controls remain effective
4. Periodically reassess risk assumptions to reflect changes in threat landscape and business context

8. Conclusion

The Enterprise Risk Management Dashboard provides a consolidated and actionable view of organizational risk exposure. While the overall risk posture is Moderate, targeted action in high-severity areas, particularly Data Breach and Access Control, will be critical to maintaining acceptable risk levels.

This executive summary supports informed governance discussions and reinforces the value of risk-based decision-making grounded in consistent assessment methodology.